

SECURITY AUDIT REPORT

NewArc (Notifier) - Phase 2

Repository: mx-chain-notifier-go-NewArc

1. Executive Summary

Following the successful remediation of the issues identified in the initial audit (CSWSH, Connection Exhaustion, and Unauthenticated Injection), a second-phase deep security review was conducted. This phase focused on production-edge cases, data integrity, and resource management under authenticated load.

Three (3) new high-severity vulnerabilities were identified. These issues primarily affect the system's resilience against Distributed Denial of Service (DDoS) and the integrity of the event stream for downstream consumers (dApps). Immediate remediation is required.

Findings Summary

ID	Title	Severity	Status
REAL-01	Improper Rate Limiting Attribution	High	OPEN
REAL-02	Silent Event Processing Failures	High	OPEN
REAL-03	Unbounded Mutation Requests	High	OPEN

3. Detailed Findings

1. Improper Rate Limiting Attribution (X-Forwarded-For)

File: dispatcher/ws/wsHandler.go · Line: 290-300

Domain: WebSocket / Networking · Severity: High - CWE-290

What This Error Is

The rate-limiting logic for WebSocket connections relies exclusively on `r.RemoteAddr`. Behind a reverse proxy, `r.RemoteAddr` reflects the proxy's IP. This leads to incorrect attribution of traffic and connection attempts.

Attack Scenario

1. Attacker initiates a flood of connection attempts.
2. Notifier blocks the Proxy IP (shared by all users).
3. All legitimate connections are dropped, resulting in a global DoS.

If Left Unfixed - What Gets Affected

Component	Impact
Rate Limiter	Becomes a weapon for attackers to trigger global DoS.
Global Availability	Service becomes unreachable for all legitimate clients.

Evidence

```
func remoteIPFromRequest(r *http.Request) string {
    host, _, err := net.SplitHostPort(r.RemoteAddr)
    if err == nil && host != "" { return host }
    return "unknown"
}
```

2. Silent Event Processing Failures (Error Ignoring)

File: process/preprocess/eventsPreProcessorV1.go · Line: 140, 157

Domain: Data Integrity / Event Pipeline · Severity: High - CWE-754

What This Error Is

The pre-processor ignores errors during Revert and Finalized block events. If the publisher fails, critical events are dropped without retrying.

Attack Scenario

1. Chain reorg occurs; Revert event pushed to Notifier.
2. Failure prevents writing to queue; error is ignored.
3. dApps miss the revert and operate on invalid state.

3. Unbounded Mutation Requests (Global Throttling)

File: api/groups/eventsGroup.go · Severity: High - CWE-770

What This Error Is

Lack of global concurrency limits on authenticated push endpoints allows an authenticated producer to flood the Notifier, exhausting CPU/Memory.

If Left Unfixed - What Gets Affected

Component	Impact
API Layer	Vulnerable to resource exhaustion from a single source.
System Stability	High risk of OOM crashes under peak load.

Evidence

```
// api/groups/eventsGroup.go
func (h *eventsGroup) pushEvents(c *gin.Context) { ... } // No throttling
```

4. Final Audit Conclusion

While the system has been hardened against external browser-based attacks, these Phase 2 findings represent significant risks to production stability. The lack of proxy-aware rate limiting (REAL-01) and the silent ignoring of critical event processing errors (REAL-02) are major concerns.

Merge Recommendation: REJECT (Pending remediation)